Prevent AiTM Phishing & Token Theft

ONE-PAGE ADVISORY

ATTACK OVERVIEW Adversary-in-the-middle phishing proxies the user's sign-in and can capture credentials, MFA responses, and session tokens. Token theft usually originates from malware, compromised endpoints, browser data, or abused refresh tokens.

KEY TAKEAWAY **Phishing-resistant authentication plus managed-device access materially reduces the value of stolen tokens.**

1 Require phishing-resistant MFA

Use passkeys/FIDO2 security keys such as YubiKey, device-bound passkeys, certificate-based authentication, or Windows Hello for Business. Start with privileged Entra and Azure roles.

LICENSE Entra ID P1;Included in Microsoft 365 Business Premium

2 Enforce authentication strength

Use Conditional Access to require the built-in/custom phishing-resistant MFA strength for admin roles and sensitive resources. Exclude and monitor emergency access accounts.

LICENSE Entra ID P1; included in Microsoft 365 Business Premium

3 Trust managed, compliant devices

Define strict Intune compliance, restrict unsupported platforms, and prefer corporate-enrolled devices. Decide explicitly where BYOD is allowed.

LICENSE Intune Plan 1 + Entra ID P1; both in Business Premium

4 Protect every endpoint

Onboard supported endpoints to Defender for Business or Defender for Endpoint and deploy tested security baselines, attack surface reduction, EDR, tamper protection, and web protection, browser and app controls etc.

LICENSE Intune Plan 1, Defender for Business in Business Premium, or Defender for Endpoint

5 Require compliant device access

Use Conditional Access to require compliant devices for corporate resources, especially admin portals and sensitive applications.

LICENSE Entra ID P1 + Intune Plan 1

6 Remove standing privilege

Use least privilege, separate admin accounts, and PIM eligible assignments. Require Authentication Context for privileged activation.

LICENSE Entra ID P2

7 Control session lifetime

For non-P2 tenants especially, enforce sign-in frequency as a compensating control with Conditional Access, for example 4 hours for admins and 8 hours for users. Test user impact and do not treat this as token-theft prevention by itself.

LICENSE Entra ID P1

8 Disable persistent browser sessions

Use Conditional Access session controls to prevent persistent browser sessions where business requirements allow.

LICENSE Entra ID P1

9 Remove unnecessary local admin

Use Windows LAPS for unique local passwords and Intune Endpoint Privilege Management where approved elevation is needed. Do not make Global Administrators local admins by default.

LICENSE LAPS supported on eligible Windows; EPM requires Intune Suite/Microsoft 365 E5

10 Monitor identity control changes

Ingest relevant Entra sign-in and audit logs to Log Analytics or Microsoft Sentinel. Detect unusual role assignment, Conditional Access, credential, and application changes.

LICENSE Azure subscription + Log Analytics/Sentinel costs

11 Review privileged access

Run recurring access reviews for high-impact Entra groups, roles, and Azure access; remove inactive or unjustified assignments.

LICENSE Entra ID P2

12 Protect email and collaboration

Use anti-phishing, Safe Links, Safe Attachments, impersonation protection, and automated investigation where licensed. Use Attack Simulation training to educate your users on catching phishing emails.

LICENSE Defender for Office 365 P1/P2

Prevent Password Spraying & Brute Force

ONE-PAGE ADVISORY

ATTACK OVERVIEW Password spraying tests a small set of common passwords across many accounts to avoid lockouts. Brute force repeatedly guesses passwords against one or more accounts. Legacy protocols are especially risky because they cannot satisfy modern MFA challenges.

KEY TAKEAWAY **MFA, password protection, smart lockout, and removal of legacy authentication shrink the usable password attack surface.**

1 Require MFA for all users

Use Conditional Access for granular enforcement. Prefer phishing-resistant methods for administrators and high-value users.

LICENSE Entra ID P1; included in Business Premium

2 Block legacy authentication

Block legacy client authentication tenant-wide with Conditional Access after validating dependencies in report-only mode.

LICENSE Entra ID P1

3 Isolate temporary exceptions

For accounts that cannot yet migrate, limit protocol exposure in Exchange Online, restrict access to trusted named locations, document ownership, and set an expiry date.

LICENSE Entra ID P1; Exchange Online P1

4 Use strong unique passwords

For remaining password-based accounts, use long unique passwords and Microsoft Entra Password Protection. Avoid routine password expiry unless compromise is suspected.

LICENSE Cloud password protection included; on-prem custom banned list needs Entra P2

5 Migrate to modern authentication

Replace legacy clients and protocols with OAuth 2.0/modern authentication. Prefer managed identities for workloads rather than user credentials.

LICENSE No additional license for protocol modernization

6 Monitor and respond

Alert on failed sign-in bursts, unfamiliar locations, targeted accounts, lockouts, and successful sign-ins following repeated failures.

LICENSE : Log Analytics required

Prevent Device Code Phishing

ONE-PAGE ADVISORY

ATTACK OVERVIEW Device code phishing tricks a user into entering a legitimate-looking code on Microsoft's sign-in page. The attacker receives the resulting token on another device without ever seeing the password.

KEY TAKEAWAY **If device code flow is not a documented business requirement, block it. If required, allow it only for narrowly defined users, devices, apps, and locations.**

1 Block device code flow

Create a Conditional Access policy to block device code flow. This single policy shuts those attacks down.

LICENSE Entra ID P1

2 Block authentication transfer

Evaluate blocking authentication transfer if your organization does not need cross-device transfer.

LICENSE Entra ID P1

3 Limit approved exceptions

Use dedicated groups, approved device platforms, named locations, and documented owners. Avoid broad tenant-wide exclusions.

LICENSE Entra ID P1

4 Train users on the signal

Tell users never to enter a device code they did not initiate. Treat unsolicited code-entry instructions as phishing and report them immediately.

LICENSE No additional license

5 Protect email and collaboration

Use anti-phishing, Safe Links, Safe Attachments, impersonation protection, and automated investigation where licensed. Use Attack Simulation training to educate your users on catching phishing emails.

LICENSE Defender for Office 365 P1/P2

Prevent OAuth Consent Attacks

ONE-PAGE ADVISORY

ATTACK OVERVIEW OAuth consent attacks persuade a user or administrator to grant a malicious application access to data. The app can retain access through tokens and permissions even after the user changes their password.

KEY TAKEAWAY **Reduce who can create, own, consent to, and approve applications, then continuously monitor permissions and app activity.**

1 Restrict user consent

Disable user consent or allow only low-risk permissions from verified publishers. Configure admin consent requests and an approval workflow.

LICENSE Entra ID Free

2 Limit app ownership

Avoid giving AppOwner to normal users. Give this role only to trusted admins. App Owner roles are basically on almost the same level as Application Administrator roles in Entra.

LICENSE Entra ID Free

3 Monitor application activity

Send Microsoft Graph activity and Entra audit logs to Log Analytics. Use Defender for Cloud Apps App Governance for OAuth app visibility and policy-based detection.

LICENSE Log Analytics + Defender for Cloud Apps

4 Prefer delegated or workload-safe design

Use delegated permissions when the app acts for a user and application permissions only when required. Prefer managed identities or certificates over long-lived client secrets.

LICENSE Entra ID Free

5 Review permissions and disable risk

Inventory enterprise apps, app registrations, owners, credentials, consent grants, and publishers. Disable suspicious or unused apps before deletion and investigation.

LICENSE Entra ID Free

6 Require assignment

Set “Assignment required” for all applications.

LICENSE Entra ID Free

7 Review app reviews regularly

Use access reviews for application access and high-risk ownership groups, prioritizing apps with broad read/write application permissions.

LICENSE Entra ID P2

8 Restrict app and agent creation

Set “Users can register applications” and "Users can create agent blueprints" to No in Entra Admin Center.

LICENSE Entra Free

9 Scrutinize multitenant apps

Review multitenant applications, publisher verification, cross-tenant exposure, and permissions. Block or constrain pathways that are not required.

LICENSE Entra ID Free

10 Detect new grants and credentials

Alert on app creation, owner changes, new credentials, admin consent, and high-impact API permission grants.

LICENSE Log Analytics, Defender for Cloud Apps recommended

Prevent LLMjacking & Cryptojacking

ONE-PAGE ADVISORY

ATTACK OVERVIEW LLMjacking and cryptojacking abuse compromised cloud identities, subscriptions, API keys, service principals, or workloads to consume paid AI or compute capacity. The result can include unexpected cost, resource exhaustion, and data exposure.

KEY TAKEAWAY **Prevent unauthorized deployment, eliminate standing privilege, protect secrets and API keys, and treat cost anomalies as security signals.**

1 Apply strong IAM, Endpoint and app hygiene

Reuse the identity, endpoint and application recommendations in the scenarios above.

LICENSE Business Premium/ Entra P2

2 Enforce Azure Policies with Azure Policy

Use ALSO Azure Policy templates in ACMP or your own Azure policies where applicable to restrict specific Azure tasks.

LICENSE Azure Policy

3 Configure budgets and alerts

Create Azure Cost Management budgets and alerts for subscriptions, resource groups, AI services, GPU compute, and other high-cost workloads.

LICENSE Azure Cost Management; notification/actions may add service costs

4 Enable Defender for Cloud

Enable the appropriate Defender for Cloud plans for deployed Azure workloads and remediate high-impact recommendations.

LICENSE Defender for Cloud plan charges apply

5 Route security alerts

Configure Defender XDR notifications to monitor security mailboxes or outsource this to SOC.

LICENSE Defender plans/Sentinel

6 Review administrative access

Use recurring access reviews for privileged groups and roles, including Azure resource access.

LICENSE Entra ID P2

7 Eliminate long-lived secrets

Prefer managed identities vs client secrets. Store unavoidable secrets and API keys in Azure Key Vault, rotate them, and monitor access.

LICENSE Key Vault usage charges may apply

8 Reduce internet exposure

Use private endpoints, network security groups, service firewalls, Azure Firewall, Bastion and JIT access where appropriate. Avoid public management interfaces.

LICENSE Azure networking

Prevent Infostealers & ClickFix attacks

ONE-PAGE ADVISORY

ATTACK OVERVIEW Infostealers collect browser data, passwords, cookies, tokens, wallets, and files. ClickFix lures users into running commands or pasted scripts, often through Run, PowerShell, Terminal, or a fake troubleshooting prompt.

KEY TAKEAWAY **Reduce execution paths, remove local privilege, control browsers and applications, and contain stolen-session impact with the AiTM controls in this pack.**

1 Apply strong IAM, Endpoint and app hygiene

Reuse the identity, endpoint and application recommendations in scenarios above.

LICENSE Business Premium/ Entra P2

2 Standardize an approved browser

Use a managed browser such as Microsoft Edge for Business. Disable built-in browser password saving if your organization uses an approved enterprise password manager.

LICENSE Intune Plan 1; Defender for Business in Business Premium

3 Control browser extensions

Block user-installed extensions by default and deploy an allowlist through Intune/Edge policies. Review existing extensions and publisher trust.

LICENSE Intune Plan 1

4 Use application control

Deploy App Control for Business. Enforce trusted applications delivered by managed channels such as Intune.

LICENSE Intune Plan 1, Defender for Business/Endpoint

5 Restrict Run where possible

Remove the Run command with Intune policy. Treat this as friction, not a complete security boundary.

LICENSE Intune Plan 1

6 Restrict use of PowerShell where possible

Restrict use of PowerShell where possible.

LICENSE Intune Plan 1

7 Remove local admin rights

Use standard users, Windows LAPS, and Endpoint Privilege Management.

LICENSE Intune Plan 1, Defender for Business or Defender for Endpoint and Intune Suite/ Microsoft 365 E5 for EPM.

8 Harden Defender protections

Enable cloud-delivered protection, tamper protection, network protection, SmartScreen, web protection, and relevant attack surface reduction rules.

LICENSE Intune Plan 1, Defender for Business or Defender for Endpoint

Reduce Ransomware Risk

ONE-PAGE
ADVISORY

ATTACK OVERVIEW Ransomware encrypts or steals data and frequently follows identity compromise, phishing, exposed remote services, unpatched vulnerabilities, or excessive privilege. Modern campaigns often combine extortion, credential theft, and lateral movement.

KEY TAKEAWAY **Ransomware resilience depends on layered prevention plus tested recovery. Endpoint detection alone is not a backup strategy.**

1 Onboard and baseline endpoints

Onboard clients and servers to the appropriate Defender plan. Deploy tested security baselines, EDR, tamper protection, cloud protection, and attack surface reduction rules.

LICENSE Defender for Business/Servers or Defender for Endpoint/Servers

2 Secure privileged sign-in

Require MFA, preferably phishing-resistant, for administrators and remote administration. Use separate admin identities and privileged access devices where feasible.

LICENSE: Group Policy, Entra P1

3 Remove public management exposure

Do not expose RDP, SSH, WinRM, hypervisor, backup, or management interfaces directly to the internet. Use Private Access, JIT, Bastion, and firewall allowlists.

LICENSE Azure/network service charges vary/ Global Secure Access Private Access

4 Patch vulnerabilities fast

Use Defender Vulnerability Management signals, Intune update policies, Windows Autopatch or / and Group Policy.

LICENSE Defender for Business/Server and up

5 Reduce privilege and lateral movement

Remove local admin, use LAPS, isolate admin accounts, segment networks, and disable unused services and protocols.

LICENSE: Group Policy

6 Seperate accounts

Use seperate accounts for on-prem and cloud tasks. Use least privilege and MIM/PIM with eligible roles and Authentication context on role activation.

LICENSE: Group Policy/Entra P1/P2

7 Protect backups from attackers

Maintain offline/immutable or logically isolated backups, separate backup admin identities, MFA, retention locks, and routine restore testing.

LICENSE Backup platform and storage licensing varies

8 Configure alert routing

Send Defender incidents and high-severity alerts to an actively monitored team or SOC. Integrate Sentinel/SIEM and automated response where appropriate.

LICENSE: Defender + Log analytics

9 Exercise recovery

Run tabletop and technical recovery exercises. Measure restores success, identity recovery, business priority order, and decision authority.

LICENSE No Microsoft license required; operational readiness is essential

DISCLAIMER All these preventive measures stated in this document do not guarantee complete protection against cyberattacks. When correctly implemented, maintained, and monitored as part of a layered security strategy, they can significantly reduce the attack surface and lower the likelihood and impact of successful attacks. Licensing requirements listed in this document may be incorrect, outdated, or contain typographical errors. Always independently verify the applicable requirements against the latest official Microsoft licensing documentation and Product Terms before making licensing or deployment decisions.

SECURITY POLICY TEMPLATES

ALSO offers many of the configurations described in this document as importable security policy templates. Find them right here. Some configurations mentioned above require manual setup. A dedicated attack prevention section on the site will be finalized in the near future.